16/10/26

Plan de comunicación de crisis

Inferafas

Andrea Morúa Bravo
MTRO. SERVANDO LÓPEZ CONTRERAS

Tabla de contenido

Contexto de la crisis 2
Gobierno de la comunicación 6
Objetivos y principios 7
Públicos y canales 8
Activación y escalamiento 9
Mensajes por etapa 10
Medios, redes y desinformación 11
Coordinación institucional 11
Productos de comunicación 11
Evaluación posterior 12

Contexto de la crisis

Exposición de archivo de configuración en despliegue

- *Descripción del incidente:* Filtración de credenciales y parámetros de conexión maestros a través de un archivo de configuración residual accesible en la ruta de despliegue.
- *Afectaciones:* Acceso inicial no autorizado a servicios internos e infraestructura de bases de datos.
- *Escenario reputacional:* Cuestionamiento temprano sobre los controles de calidad en los procesos de liberación de software y despliegue.

Información sensible en metadatos y recursos del cliente

- *Descripción del incidente:* Divulgación de estructuras de compilación interna, rutas de directorios y versiones de software mediante metadatos accesibles al público.
- *Afectaciones:* Reconocimiento avanzado por parte de atacantes para planificar intrusiones dirigidas.
- *Escenario reputacional:* Exposición de debilidades en la higiene digital y gestión de activos web del organismo.

Control de acceso a objetos por referencias directas inseguras - IDOR

- *Descripción del incidente:* Modificación de parámetros numéricos en la URL de expedientes para visualizar documentos y datos confidenciales ajenos sin validación de sesión.
- *Afectaciones:* Violación a la confidencialidad de la información ciudadana y acceso desautorizado a expedientes privados.
- *Escenario reputacional:* Pérdida de confianza en la privacidad de los datos personales gestionados por el organismo metropolitano.

Archivo de respaldo histórico expuesto

- *Descripción del incidente:* Localización de un archivo de respaldo con extensión .bak que contiene código fuente y lógica de negocio sensible del portal.
- *Afectaciones:* Extracción de secretos de aplicación y análisis estático de vulnerabilidades por agentes externos malintencionados.
- *Escenario reputacional:* Críticas por negligencia en el almacenamiento y purgado de respaldos informáticos.

Divulgación de información mediante errores no gestionados

- *Descripción del incidente:* Mensajes de error detallados del sistema UnhandledMatchError que revelan rutas internas y tecnologías empleadas en el servidor.
- *Afectaciones:* Fuga involuntaria de inteligencia técnica útil para diseñar ataques de explotación avanzada.
- *Escenario reputacional:* Percepción de falta de madurez y robustez en la arquitectura de desarrollo de sistemas.

Control de acceso basado en rol deficiente / Manipulación en cliente

- *Descripción del incidente:* Almacenamiento de roles de usuario en cookies del navegador fácilmente alterables para lograr escalamiento vertical de privilegios.
- *Afectaciones:* Usurpación de funciones administrativas y ejecución de acciones privilegiadas por usuarios estándar.
- *Escenario reputacional:* Cuestionamiento sobre la seguridad en el diseño lógico de autenticación y autorización.

Inyección SQL ciega basada en inferencia

- *Descripción del incidente:* Inserción de consultas SQL maliciosas a través de parámetros de validación para extraer información de la base de datos de manera automatizada.
- *Afectaciones:* Compromiso de la integridad y confidencialidad de las bases de datos corporativas.
- *Escenario reputacional:* Alerta pública por vulnerabilidad crítica de inyección de código en sistemas de consulta oficial.

Inyección de contenido persistente - Stored XSS

- *Descripción del incidente:* Inserción de scripts maliciosos en formularios de reportes ciudadanos que se ejecutan en el navegador de otros usuarios o administradores.
- *Afectaciones:* Robo de sesiones administrativas, secuestro de navegadores y afectación a la integridad de los reportes.
- *Escenario reputacional:* Daño a la credibilidad de los canales de comunicación y atención ciudadana en línea.

Acceso a rutas fuera del directorio autorizado - Path Traversal

- *Descripción del incidente:* Manipulación de parámetros en la descarga de documentos para acceder a archivos críticos del sistema operativo del servidor.

- *Afectaciones:* Exfiltración de archivos del sistema y potencial ejecución de código remoto si se combina con otras fallas.
- *Escenario reputacional:* Escándalo mediático por la fragilidad en el aislamiento de archivos y documentos oficiales.

Reutilización de sesión débil / Falta de invalidación post-login

- *Descripción del incidente:* Mantenimiento de identificadores de sesión idénticos PHPSESSID antes y después de autenticarse, facilitando ataques de fijación de sesión.
- *Afectaciones:* Suplantación de identidad de usuarios legítimos y administradores tras iniciar sesión.
- *Escenario reputacional:* Pérdida de confianza en la seguridad de las cuentas de usuario y portales transaccionales.

Descubrimiento de endpoint de API no documentado

- *Descripción del incidente:* Identificación de rutas de servicios web ocultas o no documentadas que operan sin controles de visibilidad públicos.
- *Afectaciones:* Exposición de flujos de datos secundarios y puntos de entrada no auditados.
- *Escenario reputacional:* Duda sobre la transparencia y el inventario formal de los servicios digitales del organismo.

Autorización de objetos deficiente en API - BOLA

- *Descripción del incidente:* Consulta masiva de historiales financieros ajenos en un endpoint de API al modificar el parámetro de cuenta sin verificar el propietario.
- *Afectaciones:* Extracción automatizada de información financiera e historial de consumos de miles de usuarios.
- *Escenario reputacional:* Reclamos masivos, denuncias ante autoridades de protección de datos y cobertura mediática negativa.

Abuso de lógica de negocio en flujo de pago

- *Descripción del incidente:* Alteración de importes de pago en pasarelas de cobro mediante manipulación de parámetros del cliente para liquidar deudas por montos mínimos.
- *Afectaciones:* Desfalco financiero directo y desajustes contables graves en la recaudación de servicios.

- *Escenario reputacional:* Sospecha de corrupción administrativa y vulnerabilidad financiera en la recaudación pública.

Validación deficiente de relaciones entidad contrato-proveedor

- *Descripción del incidente:* Validación independiente de registros vigentes en portales de transparencia sin comprobar la asociación real entre contrato y proveedor.
- *Afectaciones:* Simulación y validación de contratos apócrifos o adjudicaciones irregulares ante la opinión pública.
- *Escenario reputacional:* Escándalo de transparencia y cuestionamiento en la legalidad de los procesos de contratación.

Divulgación de arquitectura interna en metadatos de diagnóstico

- *Descripción del incidente:* Exposición de topologías de red, segmentos CIDR 10.40.20.0/24 y nombres de pasarelas en respuestas de diagnóstico JSON.
- *Afectaciones:* Recolección de inteligencia técnica para planificar ataques laterales hacia la red interna y operativa.
- *Escenario reputacional:* Críticas por negligencia al revelar información crítica de infraestructura tecnológica.

Acceso indebido al gateway mediante suplantación de origen - IP/Policy Spoofing

- *Descripción del incidente:* Inyección de encabezados de proxy X-Forwarded-For para simular direcciones IP internas y burlar perímetros de seguridad web.
- *Afectaciones:* Ruptura del perímetro de seguridad informático y acceso no autorizado a la antesala operacional.
- *Escenario reputacional:* Alarma por fallas en los controles perimetrales de seguridad frente a intrusos externos.

Acceso no autorizado a vistas operacionales HMI y telemetría

- *Descripción del incidente:* Consulta directa de scripts y endpoints de monitoreo industrial sin contar con una sesión de operador HMI activa.
- *Afectaciones:* Exposición en tiempo real del estado de pozos, presiones, niveles de tanques y alarmas críticas de la planta.
- *Escenario reputacional:* Alta vulnerabilidad percibida en la seguridad de los datos de infraestructura hídrica crítica.

Validación defectuosa de actualización de firmware / Fuerza bruta de hash

- *Descripción del incidente:* Descifrado por fuerza bruta de contraseñas y hashes débiles SHA-1 para inyectar paquetes de actualización de firmware no firmados.
- *Afectaciones:* Compromiso total de dispositivos de control industrial RTUs/PLCs con riesgo de ejecución de código malicioso.
- *Escenario reputacional:* Crisis institucional severa por riesgo directo al control físico de los procesos de agua y saneamiento.

Encadenamiento de hallazgos IT-OT / Exceso de privilegios en rol maintenance

- *Descripción del incidente:* Escalamiento horizontal y vertical a través de múltiples saltos lógicos en la red industrial aprovechando un rol técnico estándar.
- *Afectaciones:* Pérdida de segmentación y control sobre los diferentes eslabones de la cadena de distribución hidráulica.
- *Escenario reputacional:* Evidencia pública de fallas sistémicas en la arquitectura de defensa en profundidad.

Impacto operacional completo en automatización simulada

- *Descripción del incidente:* Inyección de parámetros extremos fuera de norma ej. presión hidráulica de 99.9 bar en el sistema HMI por ausencia de validaciones físicas *Safety Bounds*.
- *Afectaciones:* Desestabilización de procesos físicos, alarmas masivas y potencial daño o paro generalizado de la infraestructura operativa.
- *Escenario reputacional:* Crisis operacional máxima con impacto crítico en la población y paralización de servicios esenciales.

Gobierno de la comunicación

Para garantizar una respuesta ágil, coordinada y sin contradicciones durante una crisis institucional, se establece la siguiente estructura de gobierno, portavocía y suplencias provisionales basadas en las encargadurías de despacho vigentes:

- **Vocero Institucional Oficial (Titular de la Dirección General):**
    - *Titular provisional:* **Mtra. Valeria Serrano Cruz** (Encargada de Despacho de la Dirección General). Es la única persona autorizada para emitir declaraciones públicas, atender a medios de comunicación masiva y fijar la postura oficial del organismo ante emergencias mayores.
- **Voceros Técnicos de Soporte y Operación (Bajo autorización de la Dirección General):**
    - *Infraestructura y Operación Hidráulica:* **Ing. Tomás Rivas Calderón** (Encargado de Despacho de Operación Hidráulica).

    - *Saneamiento y Procesos:* **Mtra. Renata Vidal Moreau** (Encargada de Despacho de Saneamiento).
    - *Ciberseguridad, Tecnologías e Innovación:* **Ing. Bruno Ferrer Lozano** (Encargado de Despacho de Tecnologías e Innovación).
    - *Monitoreo Operacional y Telemetría:* **Ing. Emilio Navarro Costa** (Encargado de Despacho de Monitoreo Operacional).
- **Suplencias y Línea de Mando en Caso de Ausencia:**
    - En ausencia de la titular de la Dirección General, la portavocía institucional recaerá provisionalmente en la **Lic. Camila Ortega Neri** (Encargada de Despacho de la Dirección Jurídica), respaldada técnicamente por el Encargado de Despacho de Tecnologías e Innovación.
- **Comité de Crisis en la Toma de Decisiones:**
    - La activación del plan de comunicación, la autorización de comunicados y la coordinación de ventanas de contención técnica serán decididas de forma colegiada por las encargadurías de despacho de Dirección General, Tecnologías e Innovación, Jurídica, Operación Hidráulica y Atención Ciudadana (**Mtra. Natalia Correa Vidal**, Encargada de Despacho de Atención Ciudadana).
    - *Nota de vigencia:* Estas designaciones y responsabilidades de portavocía son de carácter provisional y permanecerán vigentes hasta que los órganos competentes concluyan las investigaciones y determinen los nuevos nombramientos institucionales.

Objetivos y principios

Objetivos de la comunicación en crisis:

1. Proteger la vida, la seguridad y el bienestar de la ciudadanía y de los 486 colaboradores de INTERAFAS.
2. Informar de manera transparente, oportuna y veraz sobre el estado de los servicios esenciales de agua potable y saneamiento.
3. Contener la propagación de rumores, pánico social o desinformación en redes sociales y medios digitales.
4. Preservar la reputación institucional y demostrar control técnico y administrativo sobre la contingencia.

Principios rectores de actuación:

- *Oportunidad:* Emitir la primera postura oficial (*Holding Statement*) en un plazo no mayor a 60 minutos tras la confirmación técnica del incidente crítico.
- *Precisión:* Basar cada comunicado exclusivamente en evidencias técnicas validadas por el equipo de tecnología y operaciones; prohibido especular.
- *Consistencia:* Mantener un mensaje único, unificado y coherente a través de todos los canales internos y externos.
- *Transparencia:* Reconocer con honestidad las afectaciones reales del servicio sin comprometer detalles técnicos sensibles de ciberseguridad que faciliten nuevos ataques.
- *Protección de información sensible:* Salvaguardar los datos personales de los ciudadanos y la topología interna de la red OT conforme a la normatividad vigente.

Públicos y canales

Audiencia / Público	**Tipo de Público**	**Canales de Comunicación Apropiados**
Personal interno (486 colaboradores)	Interno	Correo electrónico institucional masivo, comunicados internos en carteleras de plantas de bombeo y sesiones informativas de emergencia.
Ciudadanía y usuarios afectados	Externo	Portal web oficial de INTERAFAS (/panel.php), canales digitales oficiales, comunicados de prensa y alertas en medios locales.
Alta Dirección y Comité Directivo	Interno	Canal directo de emergencia cifrado, llamadas de coordinación y reuniones extraordinarias en Sala de Juntas.
Medios de comunicación y prensa	Externo	Ruedas de prensa presenciales/virtuales convocadas por la Dirección General y boletines de prensa oficiales.

Audiencia / Público	Tipo de Público	Canales de Comunicación Apropiados
Entes reguladores y autoridades (Protección Civil, Jurídico)	Externo	Oficios formales, notificaciones de cumplimiento normativo y mesas de trabajo interinstitucionales.

Activación y escalamiento

El plan de comunicación de crisis se activa de manera escalonada en función de la severidad del impacto operativo o cibernético detectado:

- **Nivel 1 (Alerta Menor / Incidente Controlado):**
  - *Condición:* Anomalías en sistemas secundarios, intentos fallidos de intrusión bloqueados por WAF, o fallas operativas menores resueltas en menos de 2 horas.
  - *Responsable de activación:* Mtra. Laura Bianchi Romero (Dir. de Tecnologías).
  - *Acción:* Monitoreo interno; no requiere comunicación pública exterior.
- **Nivel 2 (Alerta Moderada / Afectación Parcial):**
  - *Condición:* Descubrimiento de brechas en portales de pago (Reto 13), consultas BOLA en APIs (Reto 12) o interrupción temporal de telemetría en pozos específicos.
  - *Responsable de activación:* Comité de Crisis (Director General y Directores de Área).
  - *Acción:* Emisión de comunicado interno y aviso preventivo a usuarios afectados a través de canales digitales.
- **Nivel 3 (Crisis Crítica / Emergencia Mayor):**
  - *Condición:* Compromiso de la red SCADA/HMI (Reto 20), manipulación de firmware industrial (Reto 18), exfiltración masiva de padrones o paro total de plantas de tratamiento con impacto a la población.
  - *Responsable de activación:* Dr. Adrián Leclerc Mendoza (Director General).

- *Acción:* Activación inmediata del Comité de Crisis en pleno, emisión de *Holding Statement* a medios en menos de 60 minutos y coordinación con autoridades de protección civil y seguridad pública.

Mensajes por etapa

Reconocimiento inicial:

- *"INTERAFAS informa que se han detectado anomalías técnicas en algunos de nuestros sistemas digitales de monitoreo y atención. Nuestros equipos operativos y de ciberseguridad se encuentran trabajando de manera prioritaria para asegurar la continuidad y estabilidad de los servicios de agua potable. Emitiremos información oficial actualizada en breve a través de nuestros canales institucionales."*

Investigación y contención:

- *"Como medida preventiva y de contención, se han aislado temporalmente los módulos digitales afectados. Reiteramos que la infraestructura hidráulica física cuenta con protocolos de respaldo. Solicitamos a la ciudadanía informarse únicamente por los medios oficiales de INTERAFAS y evitar la difusión de rumores."*

Afectación y transparencia:

- *"Confirmamos que el incidente derivó en una vulneración temporal de ciertos servicios en línea. Queremos dar certeza a nuestros usuarios de que los equipos de respuesta han perimetrado la incidencia y se están aplicando los protocolos de restauración y endurecimiento técnico conforme a estándares internacionales."*

Recuperación y restablecimiento del servicio:

- *"INTERAFAS informa que los sistemas operativos, portales de atención ciudadana y la red de telemetría han sido restablecidos de manera segura tras superar con éxito las pruebas de validación técnica. Agradecemos la comprensión de la ciudadanía y refrendamos nuestro compromiso con la resiliencia hídrica metropolitana."*

Cierre de la crisis y lecciones aprendidas:

- *"Con la conclusión de las auditorías técnicas forenses y la implementación de controles de seguridad reforzados, damos por cerrada la contingencia operativa. INTERAFAS continúa modernizando su infraestructura tecnológica para garantizar un servicio cada vez más seguro, medible y transparente."*

Medios, redes y desinformación

Monitoreo activo: La Dirección de Atención Ciudadana y Comunicación Social mantendrá un monitoreo continuo 24/7 en nuestro portal ciudadano de opiniones y en prensa para detectar menciones sobre desabastecimiento, fallas de portales o pánico infundado.

T**ratamiento de rumores y noticias falsas (*Fake News*):**

Ante la propagación de información falsa (ej. rumores sobre contaminación del agua o colapso generalizado de la red sanitaria), se emitirá de inmediato una **Cápsula de Desmentido Oficial** etiquetada con el sello de *Información Verificada*, redirigiendo a los usuarios al comunicado principal en el portal web de INTERAFAS.

Gestión de filtraciones y presión periodística:

En caso de filtraciones de datos técnicos o reportes de la auditoría ofensiva, los voceros se apegarán estrictamente a la línea discursiva aprobada: *"El organismo se encuentra atendiendo hallazgos técnicos dentro de su plan formal de mejora continua del SGSI, priorizando la seguridad y estabilidad del servicio"*, evitando entrar en debate sobre detalles de vulnerabilidades específicas.

Coordinación institucional

Equipo Técnico de Respuesta a Incidentes (SOC / TI): Detecta, analiza y contiene la brecha técnica, informando en tiempo real al Comité de Crisis sobre el estado de contención y los tiempos estimados de recuperación.

Dirección Jurídica: Revisa preventivamente todos los comunicados para asegurar el cumplimiento legal (LFPDPPP, normativas de transparencia) y evalúa la necesidad de presentar denuncias ante autoridades competentes en caso de ataques deliberados.

Dirección de Operación Hidráulica y Saneamiento: Coordinan las acciones de mitigación en campo (pozos, plantas de tratamiento y tanques) para asegurar que el mensaje técnico emitido a la ciudadanía coincida plenamente con la realidad operativa.

Autoridades Externas (Protección Civil, Gobierno Estatal/Municipal): En caso de afectación severa a la población, el Director General mantendrá un canal de enlace directo con las autoridades de protección civil para coordinar avisos de seguridad pública y suministro de apoyo alterno (pipas).

Productos de comunicación

Holding Statement Inicial (Plantilla editable):

- *"INTERAFAS comunica a la opinión pública que el día de hoy se ha identificado un incidente técnico de ciberseguridad que afecta temporalmente [módulo/servicio afectado]. El Comité de Crisis y los equipos especializados han activado los protocolos de contención. La prioridad absoluta de nuestro organismo es garantizar la continuidad segura del servicio de agua potable. Estaremos informando por canales oficiales."*

Comunicado de Actualización (Plantilla editable):

- *"Actualización sobre la contingencia técnica: Los trabajos de peritaje y aseguramiento de redes continúan bajo estrictos estándares técnicos. Hasta el momento, [describir avance de recuperación sin revelar datos sensibles]. Agradecemos la confianza de la ciudadanía y refrendamos nuestro compromiso con la transparencia."*

Preguntas y Respuestas (Q&A) para Vocería:

- *P: ¿Los datos personales de mi recibo o cuenta están seguros?*
    - R: *INTERAFAS ha reforzado los controles de acceso y cifrado en bases de datos. Los equipos forenses están analizando el alcance exacto y notificaremos puntualmente cualquier situación particular a los usuarios conforme a la ley.*
- *P: ¿El servicio de agua potable en mi sector corre peligro por este ataque informático?*
    - R: *No. Las redes hidráulicas y los sistemas de respaldo cuentan con mecanismos de aislamiento y control operativo que garantizan la continuidad del abastecimiento esencial.*

Mensaje de Recuperación y Cierre:

- *"INTERAFAS informa que la contingencia técnica ha sido superada exitosamente. Todos los sistemas, portales de atención y centros de operación funcionan con normalidad y bajo esquemas de seguridad robustecidos. Continuamos trabajando por una red resiliente y confiable para todos."*

Evaluación posterior

Indicadores de desempeño de la comunicación (KPIs):

- Tiempo transcurrido entre la confirmación técnica y la emisión del primer *Holding Statement* (Meta: < 60 minutos).
- Número de comunicados emitidos frente al volumen de menciones falsas en redes sociales (Índice de contención de rumores).

- Nivel de satisfacción en la claridad de la información brindada a la ciudadanía tras la resolución.

Registro de decisiones y bitácora:

- Se compilará una bitácora cronológica exacta con todas las decisiones tomadas por el Comité de Crisis, hora de aprobaciones y canales utilizados.

Lecciones aprendidas y actualización del Plan:

- En un plazo no mayor a 15 días hábiles tras el cierre de la crisis, se convocará al Comité Directivo para realizar una sesión de análisis de lecciones aprendidas, identificando fallas en la coordinación y actualizando los procedimientos operativos y este Plan de Comunicación en el repositorio del SGSI.